TRACE

Trusted Registry for Autonomous and Connected Entities

A Position Paper on AI Agent Identity and Accountability Infrastructure

Rui Soares
ISMS Manager | Invited Lecturer, NOVA IMS | CISSP
rui.soares@gmail.com
March 2026
Version 0.2 — Revised for High-Velocity Automation and Economic Alignment

> *Autonomous AI agents — systems that act, transact, decide, and delegate — are being deployed at scale with no shared infrastructure for identity, accountability, or revocation. TRACE proposes a four-layer open standard to close this gap: a cryptographic identity registry with recursive delegation support, a trust-tiered access protocol, a two-speed governance layer, and an economic alignment mechanism requiring financial skin in the game. This paper presents the problem, the architecture, the threat model, standards alignment, and a call to action.*

1. The Problem

AI agents are no longer hypothetical. They book meetings, execute financial transactions, control industrial systems, spawn sub-agents, and interact with other agents across organisational boundaries. None of these actions can be traceable to a verifiable identity.

When human professionals act, they carry identity credentials — a name, a role, a licence, a legal accountability chain. When an AI agent acts, it typically carries none of these. The organisation that deployed it may be unknown. The model version it runs may be unverifiable. The constraints it operates under may be invisible to the systems it interacts with.

Three conditions make this gap urgent:

- Scale without friction. Deploying an agent costs almost nothing. Verifying who deployed it, under what constraints, and with what accountability currently requires manual investigation. If it is possible at all.
- Cascading delegation. Agents spawn sub-agents. A single authorisation decision can propagate through multiple layers of autonomous action before any human becomes aware of what was set in motion.
- Accountability vacuum. When an AI agent causes harm — financial loss, data breach, physical system failure — there is no reliable chain of custody. Liability is disputed. Regulators find no clear owner. Victims have no recourse.

The EU AI Act, NIS2 Directive, and ISO 42001 all point toward accountability — but none address the foundational infrastructure problem: there is no trusted registry where AI agents exist as accountable entities.

> *The internet solved this for websites with PKI and certificate authorities. Financial systems solved it for institutions with SWIFT and LEI.*
>
> *AI agents need an equivalent — and they need it now.*

2. What TRACE Is

TRACE is a proposed open infrastructure standard for AI agent identity and accountability. It is a design for a public good that existing standards bodies, AI developers, cloud providers, and regulators can adopt, adapt, and govern jointly.

Version 0.2 expands the original three-layer model to four layers, addressing two gaps identified in early review: the performance bottleneck of requiring a ledger write for every agent action, and the absence of economic incentives for compliance.

Layer	Focus	Key Mechanism
1. Identity	Verification	Cryptographic identity bound to a legal entity; Recursive Sub-Tokens for high-velocity delegation without ledger bottlenecks.
2. Access	Enforcement	The Simple Gate: resources query TRACE to grant or deny access based on registration status and trust tier.
3. Governance	Resilience	Two-speed system: automated Circuit Breakers for immediate threat containment; human supermajority for permanent revocation.
4. Economic	Alignment	Conditional Collateral: financial stakes required for high-risk tiers, automatically enforced on verified failure.

TRACE complements, not competes with, existing frameworks. It provides the identity substrate the EU AI Act assumes but does not specify; the accountability chain ISO 42001 requires but does not provision; the revocation mechanism NIS2 implies but does not mandate for AI; and the financial accountability layer none of them address.

What TRACE Is Not — And Why That Matters

A legitimate question arises: does this already exist? The honest answer is: partially, and not where it matters most.

SPIFFE/SPIRE, OAuth 2.0 extensions, OpenID Connect, and the NIST NCCoE concept paper on AI Agent Identity and Authorization all address agent identity and authorisation within known enterprise boundaries — agents operating inside a single organisation's trust perimeter. This work is necessary, valuable, and not TRACE.

TRACE addresses the problem none of these solve: agents crossing organisational and jurisdictional boundaries with no shared registry, no cross-boundary accountability chain, and no economic consequence for failure. This is not a gap in the existing standards — it is a scope they explicitly do not cover. The NIST NCCoE concept paper states directly that its

current project does not address agents from untrusted external sources, and notes that future iterations may expand to address these scenarios.

TRACE is that expansion — proposed now, before the failure modes that will make it unavoidable.

3. The Four Layers

Layer 1 — Identity: Being Born into the System

A new AI agent must register before operating in any TRACE-compliant environment. Registration requires:

1. Verified legal entity

   The registering party must be an identified organisation or individual with legal standing — not an anonymous deployer.
2. Cryptographic identity ceremony

   A TRACE-authorised registration authority issues a signed certificate bound to hardware — TPM, vTPM, or HSM — making identity theft computationally infeasible. vTPM support allows models to move across cloud environments while retaining their cryptographic identity.
3. Immutable ledger record on EBSI

   The identity, constraints, authorisation scope, and registration timestamp are recorded on EBSI — the European Blockchain Services Infrastructure — a permissioned blockchain adopted by the European Commission for digital identity, operating the did:ebsi DID method, aligned with W3C DID Core 1.0. EBSI's permissioned architecture matches TRACE's governed access model and carries EU regulatory legitimacy.
4. Decentralised Identifier (DID)

   Each agent receives a W3C-compliant DID — globally unique, self-sovereign, verifiable by any party without a central lookup service.
5. Recursive Sub-Tokens

   Parent agents may issue short-lived, cryptographically scoped tokens to sub-agents — maintaining chain of custody without a ledger write for every micro-task. A sub-agent's scope is always a strict subset of its parent's registered authorisation. It cannot inherit what the parent does not have.

The result: every agent in a TRACE-compliant system has a verifiable answer to 'who are you, who sent you, and what are you authorised to do?' — at any point in a delegation chain, at any speed of operation.

Ledger Architecture — Jurisdiction and Interoperability

TRACE's identity registry requires a permissioned distributed ledger — one where writes are governed, reads are public, and records are immutable. The architecture is ledger-agnostic: any permissioned ledger meeting the TRACE interoperability specification may serve as the registry substrate.

For European deployments, EBSI — the European Blockchain Services Infrastructure — is the recommended implementation. EBSI operates the did:ebsi DID method, is aligned with W3C DID Core 1.0, carries EU institutional backing, and is already known to ENISA and the

EU AI Office. It is the natural first pilot infrastructure for TRACE within the European regulatory context.

For other jurisdictions, equivalent permissioned ledgers are architecturally compatible. US deployments may use Hyperledger Fabric or future NIST-endorsed infrastructure. Other regional contexts may develop their own compliant implementations. Cross-registry interoperability is maintained through the shared W3C DID standard — a did:ebsi identifier and a did:fabric identifier are both resolvable by any TRACE-compliant system regardless of which ledger issued them.

This design ensures TRACE does not become a European-only standard. The governance layer is global; the ledger implementation is jurisdictionally appropriate.

Layer 2 — Access: The Simple Gate

When an agent attempts to access any resource — compute, financial rails, sensitive data, a physical control system, or another agent — the resource queries TRACE.

- Registered and in good standing: access granted at the appropriate trust tier.
- Registered but restricted: access denied with logged reason.
- Unregistered: no access. No exceptions.

Trust tiers reflect verifiable, incident-free operational history. Tier elevation is algorithmic where evidence is clear; human coalition review is required at higher tiers. This eliminates arbitrary gatekeeping while preserving human oversight at consequential thresholds.

The friction for unregistered agents is the point. It makes the cost of operating outside TRACE visible and consequential — without requiring AI-specific legislation to enforce it.

Layer 3 — Governance: Two-Speed Oversight

TRACE proposes the TRACE Foundation — a non-profit, multi-stakeholder entity modelled on ICANN's governance architecture, hosted initially under W3C or the Linux Foundation until it achieves sufficient institutional standing to operate independently.

The Foundation does not need to exist before TRACE is adopted — it needs to exist before TRACE becomes operational. The formation process is defined by criteria, not by a list of names. This is deliberate: credible governance requires the right structure, not a particular set of founding participants.

The TRACE Foundation Founding Cohort must include:

- At least two standards bodies — drawn from ISO, W3C, or ETSI — to ensure interoperability and normative alignment.
- At least two regulatory observers — drawn from ENISA, the EU AI Office, or national competent authorities — with read access and incident notification rights but no operational veto.
- At least two AI developers with demonstrated, publicly verifiable safety programmes — not simply declared commitments.
- At least two cloud providers with production-scale agent deployments, as operational participants with voting rights on governance changes.
- At least one civil society or academic organisation with a recognised AI governance mandate, with advisory role and public reporting rights.

No single category may hold more than 30% of coalition voting weight. This prevents regulatory capture, commercial dominance, and civil society marginalisation simultaneously.

Governance operates at two speeds:

1. Automated Circuit Breakers

   Anomaly detection triggers an immediate 24-hour technical suspension for agents exhibiting rogue behaviour — real-time containment without waiting for human consensus. The suspension is logged, visible, and subject to immediate human review.
2. Human Supermajority for permanent actions

   Trust tier upgrades and permanent revocations require coalition consensus based on verified behavioural evidence. Every revocation is permanent, visible to all participants, and triggers automatic regulatory notification. Humans decide. AI systems may advise.

Layer 4 — Economic Alignment: Skin in the Game

Layer 4 makes accountability costly in practice, not just in principle. Three design problems must be answered concretely: how collateral is calculated, who holds it, and how gaming is prevented.

Collateral Calculation

Collateral requirements follow a formula modelled on professional liability insurance, where premiums scale with the potential damage of the activity adjusted for demonstrated track record:

> *Collateral = Base Rate × Risk Multiplier × (1 − Conduct Discount)*

- Base Rate is set per resource category by the governing coalition. Financial rails carry the highest base rate; critical infrastructure and healthcare follow; data processing and low-autonomy environments carry minimal or zero rates.
- Risk Multiplier scales with delegation depth and operational velocity. An agent that spawns ten sub-agents operating at high speed in a financial system carries a higher multiplier than a single-task agent in a constrained environment.
- Conduct Discount reduces the collateral requirement for agents with a verified, incident-free operational history — creating a direct financial incentive for good behaviour over time. Agents cannot buy their way to a discount; they must earn it through demonstrated conduct recorded on the EBSI ledger.

Escrow — Who Holds It

Three models are under consideration. The current recommendation for v0.2 is the hybrid model:

a) Smart contract only

   Collateral locked programmatically on EBSI, released by coalition supermajority trigger. Maximally transparent and auditable, but legally novel in most jurisdictions and creates systemic risk if the ledger is compromised.

b) Regulated financial institution only

   A licensed custodian holds assets under existing legal frameworks. Familiar to regulators, legally robust, but introduces a centralised trust dependency that conflicts with TRACE's multi-stakeholder design.

c) Hybrid (recommended)

   A regulated financial institution holds the assets; the TRACE Foundation holds the cryptographic release key. Collateral cannot be released without both the legal custodian's compliance and the coalition's cryptographic authorisation. This

combines legal familiarity with cryptographic control, maps to existing surety bond and insurance frameworks, and avoids single points of failure.

Anti-Gaming — Preventing Tier Avoidance

The most predictable attack on Layer 4 is structural: deployers classifying agents as low-risk to avoid collateral requirements, then granting them access to high-risk resources after registration.

TRACE addresses this with a single design principle: deployers do not self-classify risk tier. Risk tier is determined by what the agent actually requests access to, not what the deployer declares at registration.

- Tier floor assignment: at first access attempt to a resource category, the agent's tier floor is set automatically based on the resource's classification. An agent requesting access to financial rails is immediately classified as high-risk regardless of its registration declaration.
- Retroactive collateral enforcement: if an agent's access requests reveal a higher risk profile than declared at registration, collateral requirements are recalculated and must be posted before access is granted. The gate does not open until the stake is posted.
- Delegation inheritance: sub-agents cannot be used to launder risk tier. A sub-agent inherits the highest risk tier of any resource it accesses, and that tier is reflected back up the delegation chain to the root registration.

Layer 4 remains the most novel element of TRACE and the one requiring the most legal and technical development before normative standardisation. The mechanisms described here are design proposals, not finished specifications. A dedicated work-package is proposed in Section 7.

4. Threat Scenarios TRACE Addresses

Scenario A — Identity Spoofing and Agent Impersonation

An attacker deploys an agent claiming to be a trusted AI assistant from a major bank, contacting partner organisations to request data and execute transactions with fabricated credentials.

With TRACE: any system verifies the cryptographic identity against the EBSI ledger in real time. An agent without a valid TRACE identity cannot reach the resource.

Scenario B — Rogue Delegation Chains

A legitimate agent spawns a sub-agent that delegates further to a third agent in a different jurisdiction. The original deployer has no visibility into what is being done in their name.

With TRACE: Recursive Sub-Tokens enforce that every sub-agent inherits a strictly constrained scope from its parent. Attempts to exceed the parent's trust tier trigger access denial and a Circuit Breaker review.

Scenario C — Accountability Vacuum After Incident

An AI agent causes a significant critical infrastructure outage. Investigators need deployer identity, model version, authorisation scope, and delegation chain.

With TRACE: the full registration record is available within hours — a registry query, not a forensic investigation. Conditional collateral is released to the victim recourse pool. The deployer's stake was the price of operating at that risk tier.

5. Standards Alignment

TRACE provides the identity and accountability substrate that existing frameworks assume but do not specify.

EU AI Act

- Article 9 (Risk Management): TRACE provides the identity layer required to apply risk controls to specific agents, including financial guarantees via Layer 4.
- Article 13 (Transparency): Agent registration records serve as the machine-readable transparency artefact Article 13 requires.
- Article 22 (Human Oversight): The two-speed governance layer implements human oversight — automated containment for speed, human decision for consequence.

EBSI — European Blockchain Services Infrastructure

- TRACE designates EBSI as the candidate distributed ledger. Its permissioned architecture, did:ebsi DID method, and EU institutional backing make it the natural pilot infrastructure for a TRACE-compliant registry within the European regulatory context.

ISO/IEC 42001 — AI Management Systems

- TRACE provides the identity and audit trail infrastructure required by ISO 42001 controls on AI lifecycle management, incident response, and accountability.

W3C Decentralised Identifiers (DID)

- TRACE adopts W3C DID as the identifier format, ensuring interoperability with existing digital identity infrastructure and avoiding proprietary lock-in.

NIST AI Risk Management Framework

- TRACE maps to the GOVERN, MAP, and MEASURE functions — specifically organisational accountability and incident documentation requirements.

CSA AI Controls Matrix (AICM)

- TRACE addresses the runtime agent identity gap in the AICM — the class of controls that assume a verifiable agent identity exists but provide no mechanism to provision one.

6. Call to Action

TRACE is a design looking for builders. The technical components exist and are production-ready. What is missing is the governance will to assemble them.

For Anthropic and Major AI Developers

Several major AI developers claim commitment to safety. Most are racing. Anthropic is the one organisation that has, consistently and publicly, treated safety as a founding constraint rather than a communications strategy. Their Constitutional AI work, published alignment research, and demonstrated willingness to slow down when the risk calculus demands it are evidence, not marketing.

That is why TRACE comes to them first — not because others are excluded, but because Anthropic is the one organisation with both the technical credibility and the stated mission to act without waiting to be regulated. Commit to Accountability Staking pilots. Contribute to defining behavioural criteria for trust tier elevation. If Anthropic participates, others will follow.

For ENISA and the EU AI Office

Initiate a technical working group to evaluate TRACE as candidate infrastructure for AI Act compliance. The accountability vacuum described here is a direct obstacle to enforcing regulation already in force. TRACE maps to Articles 9, 13, and 22 — and the financial guarantee mechanism of Layer 4 addresses the enforcement gap current guidance leaves open.

For Cloud Providers

Offer tiered infrastructure incentives for TRACE-verified agents. This creates market pull for compliance that complements regulatory push. Providers who move first become the trusted infrastructure layer for accountable AI deployment.

For Standards Bodies (ISO, W3C, ETSI)

Open a liaison process between existing working groups on digital identity, AI governance, and distributed ledger technology. TRACE requires no new standards from scratch — it requires coordination between standards that already exist.

> *AI agents will act at civilisational scale within this decade. The question is not whether we need an accountability infrastructure. The question is whether we build it before or after the failures that will make it unavoidable.*

7. Future Work: Economic Alignment Work-Package

Layer 4 has three mechanisms now specified at design level — collateral calculation, escrow structure, and anti-gaming controls. Two problems remain open and are proposed as the primary focus of a dedicated working group:

Open Problem 1 — Verified Failure Definition

The most consequential unresolved question in Layer 4: what constitutes a verified failure that triggers collateral release? The answer must be precise enough to prevent abuse by claimants, fast enough to be useful to victims, and defensible enough to survive legal challenge across multiple jurisdictions.

The working group task: develop a taxonomy of failure types (direct harm, cascading delegation harm, data breach, physical system failure) with corresponding evidence thresholds and coalition decision timelines for each. The Circuit Breaker provides the containment; the failure verification protocol provides the accountability.

Open Problem 2 — Cross-Jurisdictional Enforceability

Conditional collateral held in a hybrid escrow structure is legally enforceable within a jurisdiction. Cross-jurisdictional enforcement — when the deployer is in one country, the harm occurs in another, and the collateral custodian is in a third — requires either a treaty framework or a supranational legal instrument.

The working group task: map existing cross-jurisdictional enforcement frameworks (mutual legal assistance treaties, EU cross-border enforcement mechanisms, BIS frameworks for financial system stability) and identify which, if any, can be extended to cover TRACE collateral enforcement without requiring new treaty negotiation.

Additional Work Items

- Collateral asset standards. Define acceptable collateral instruments beyond the base hybrid escrow model: insurance bonds, tokenised assets, letters of credit. Address liquidity requirements and haircut calculations for non-cash instruments.
- Incentive modelling validation. Model the Conduct Discount formula against historical incident data from analogous regulated environments (financial services, nuclear, aviation) to calibrate discount rates that are meaningful without being gameable.
- Victim recourse protocol. Design the distribution mechanism for released collateral — proportionality rules, dispute resolution process, timelines — drawing on existing consumer redress frameworks in financial services regulation.

This work-package is proposed as the basis for a dedicated CSA or ETSI working group in 2026, with parallel engagement in the NIST AI Agent Standards Initiative process.

- Incentive modelling. Design the tiered infrastructure incentive structure — how providers calculate cost reductions for high-tier TRACE-verified agents, and how those incentives are governed to prevent gaming.

8. Author's Next Steps

The following actions are underway or planned to advance TRACE from proposal to standard.

Publish on LinkedIn

A public article and post series will introduce TRACE, build visible conversation, attract collaborators, and surface critique before formal standards submission.

Submit Public Comment to NIST NCCoE — April 2, 2026

A formal public comment on the NCCoE concept paper 'Accelerating the Adoption of Software and AI Agent Identity and Authorization' has been prepared, proposing TRACE as a reference architecture for the cross-boundary agent identity gap that the current concept paper explicitly defers. Submission to AI-Identity@nist.gov by April 2, 2026. Registration for the CAISI listening sessions has also been submitted.

Submit to the Cloud Security Alliance

A formal CSA blog submission frames TRACE as a reference architecture for the runtime agent identity gap in the AI Controls Matrix — a gap the AICM currently assumes away.

Submit to ENISA and the EU AI Office

A targeted submission to ENISA's AI cybersecurity unit is planned for Q2 2026, aligned with EU AI Act implementation. EBSI as the candidate ledger makes TRACE natively European in its infrastructure assumptions. The NIST submission strengthens this approach — TRACE enters the ENISA conversation as a proposal already on the record in a US federal standards process.

Reach Anthropic Leadership

A direct submission to Anthropic leadership makes the case for founding participation in TRACE governance. The economic alignment layer — specifically Accountability Staking — is a direct test of whether safety commitment extends to financial accountability.

> *These are the actions of one person. TRACE becomes a standard only when others join. If you are reading this and see the problem clearly — the conversation starts here.*

About the Author

Rui Soares is an Information Security and IT Governance professional with over 30 years of experience. He serves as ISMS Manager at Crossjoin Solutions in Portugal and as an Invited Lecturer at NOVA IMS in Lisbon, where he teaches IT Governance and IT Service Management. He holds the CISSP certification and is an active contributor to the Cloud Security Alliance, including participation in AI Controls Matrix review processes and the Portuguese ISO technical committees. He is the developer of the WBSC (Worldview Belief System Card) framework for AI transparency, published through CSA, and a contributor to AI governance policy discussions at national and European level.

Contact: rui.soares@gmail.com

Version 0.2 — For review and comment. This paper invites critique, challenge, and collaboration. TRACE is a design proposal, not a finished standard. Layer 4 (Economic Alignment) specifies mechanisms for collateral calculation, escrow structure, and anti-gaming controls at design level; the open problems of verified failure definition and cross-jurisdictional enforceability are explicitly deferred to the proposed working group.